

Executive Decision Brief

Ticket #005 — Executive Decision Brief

Situation

A critical vulnerability was identified in Apache HTTP Server 2.4.50 supporting the Employee Operations Portal.

The application is business-critical and actively used by employees.

Immediate shutdown would reduce security exposure but would also interrupt business operations.

Our assessment confirmed that the vulnerable software version was installed, running, and reachable.

However, existing configuration controls materially reduced observed exploitability, and no evidence of active exploitation was identified.

Risk

The security risk was significant because Apache 2.4.50 is affected by CVE-2021-42013, a vulnerability with known real-world exploitation.

At the same time, the immediate operational risk of taking a business-critical application offline during working hours was also significant.

The key issue was therefore not whether the vulnerability was serious, but whether immediate business disruption was justified by the actual exposure observed in this environment.

Options

Four response options were evaluated:

1. Immediately shut down the application and remediate.
2. Perform an emergency business-hours upgrade.

3. Maintain verified compensating controls while preparing an expedited controlled remediation.
4. Wait until the normal weekend maintenance window.

The risk decision matrix favored Option 3.

Recommendation

Maintain application availability while verifying compensating controls and enhanced monitoring, then perform an expedited controlled Apache upgrade before the normal weekend maintenance window.

Do not leave Apache 2.4.50 in service longer than necessary.

Escalate to immediate containment if evidence of exploitation, increased exposure, or failure of compensating controls appears.

Business Impact

The selected approach avoided an immediate business-hours outage.

The replacement Apache version was tested before production cutover.

The Employee Operations Portal remained operational after remediation.

Existing unrelated services were unaffected.

The final production-simulation service is operating normally on Apache HTTP Server 2.4.68.

Result

The vulnerable Apache 2.4.50 service was successfully replaced with Apache 2.4.68.

Security validation passed.

Functional validation passed.

Operational validation passed.

Monitoring validation passed.

A non-fatal Apache ServerName configuration warning was discovered during post-change validation, corrected, tested, and successfully revalidated.

Residual Risk

The specific risk associated with actively running Apache 2.4.50 has been removed.

Residual risk remains from normal application, infrastructure, configuration, and future software vulnerabilities.

The service remains network reachable and depends on a single active container.

Continued patch management, monitoring, configuration control, and availability planning are recommended.

Overall residual risk is assessed as:

LOW-MEDIUM

Recommendation Confidence:

HIGH